

Mission d'Expertise en Cybersécurité : Analyse de risques et sécurisation d'organisations critiques

Projet PACTE 4A - option cybersécurité

Réalisé par :
Sami ELABSSI
Wassim NAFID
Fatima Ezzahra MONTASSIF
Oussama MAKHOUKH

Encadré par :
M. GAOUAR Omar

Table de matières

Table de matières.....	2
Introduction.....	3
Présentation de l'architecture.....	3
Plan de Tests et Résultats.....	4
Test 1 : Continuité de service (Haute disponibilité).....	4
Test 2 : Sécurité VPN.....	5
Test 3 : Connectivité réseau globale.....	7
Test 4 : Supervision et journalisation (SIEM).....	8
Test 5 : Sécurité DHCP (DHCP Snooping).....	8
Conclusion.....	11

Introduction

Ce document présente les tests réalisés pour valider l'architecture réseau sécurisée proposée pour Akdital.

L'objectif principal de ces tests est de valider :

- La disponibilité des services
- La sécurité des communications
- La résilience de l'architecture
- La traçabilité des événements réseau

Présentation de l'architecture

L'infrastructure mise en place repose sur les éléments suivants :

- Segmentation réseau via VLANs :
 - VLAN médical
 - VLAN administratif
 - VLAN visiteurs
- Une zone DMZ hébergeant les services exposés
- Deux firewalls internes configurés en redondance (HSRP)
- Un firewall externe assurant :
 - Le NAT
 - Le VPN IPsec
- Un système SIEM pour la supervision et la journalisation
- Mise en place de mécanismes de sécurité :
 - ACL (contrôle d'accès)
 - DHCP Snooping
 - VPN sécurisé

Plan de Tests et Résultats

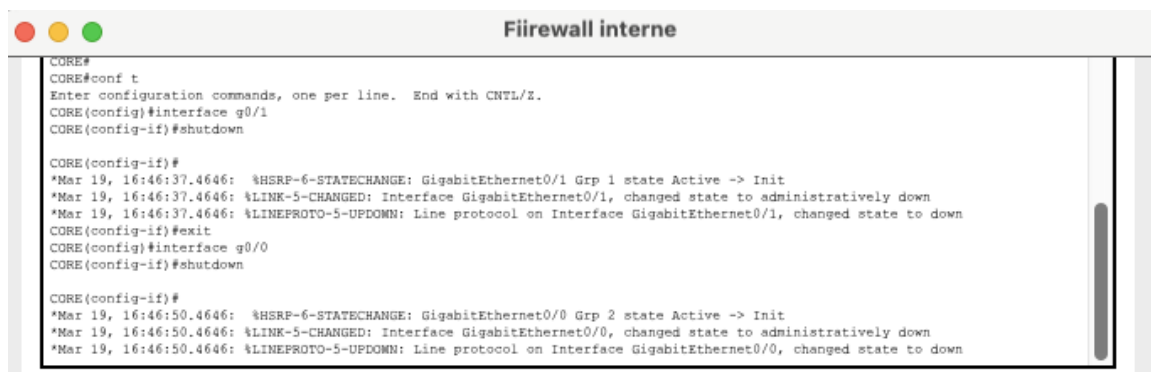
Test 1 : Continuité de service (Haute disponibilité)

Objectif :

Vérifier la capacité du système à fonctionner en cas de panne d'un équipement principal.

Procédure :

1. Simuler une panne :
 - Désactiver les 2 connexions du firewall principal

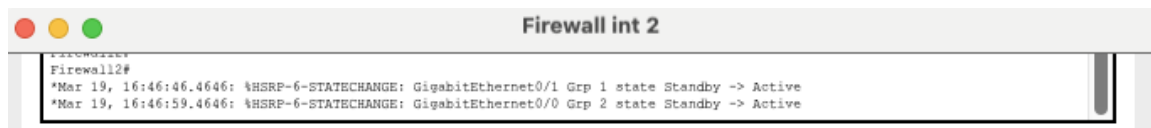


```
CORE#
CORE#conf t
Enter configuration commands, one per line. End with CNTL/Z.
CORE(config)#interface g0/1
CORE(config-if)#shutdown

CORE(config-if)#
*Mar 19, 16:46:37.4646: %HSRP-6-STATECHANGE: GigabitEthernet0/1 Grp 1 state Active -> Init
*Mar 19, 16:46:37.4646: %LINK-5-CHANGED: Interface GigabitEthernet0/1, changed state to administratively down
*Mar 19, 16:46:37.4646: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/1, changed state to down
CORE(config-if)#exit
CORE(config)#interface g0/0
CORE(config-if)#shutdown

CORE(config-if)#
*Mar 19, 16:46:50.4646: %HSRP-6-STATECHANGE: GigabitEthernet0/0 Grp 2 state Active -> Init
*Mar 19, 16:46:50.4646: %LINK-5-CHANGED: Interface GigabitEthernet0/0, changed state to administratively down
*Mar 19, 16:46:50.4646: %LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0, changed state to down
```

2. Attendre quelques secondes

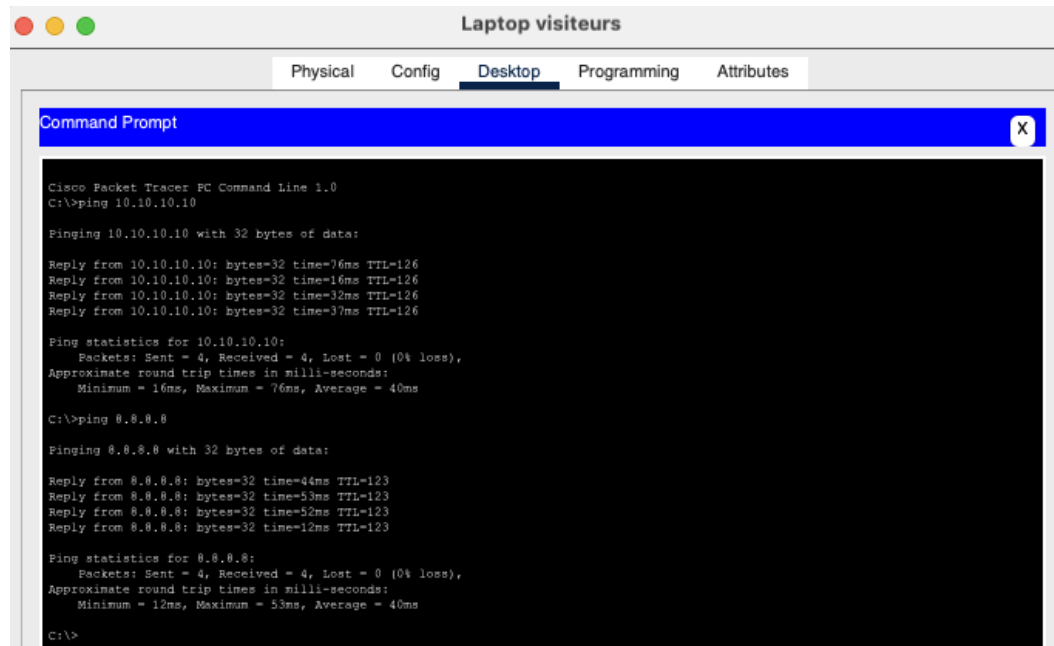


```
Firewall2#
*Mar 19, 16:46:46.4646: %HSRP-6-STATECHANGE: GigabitEthernet0/1 Grp 1 state Standby -> Active
*Mar 19, 16:46:59.4646: %HSRP-6-STATECHANGE: GigabitEthernet0/0 Grp 2 state Standby -> Active
```

Normalement, le firewall interne secondaire sera actif afin d'assurer la redondance.

3. Tester la connexion :
 - Ouvrir un PC (LAN)
 - Tester l'accès avec le ping :

ping 8.8.8.8 ou ping 10.10.10.10



Résultat attendu :

- Basculement automatique vers le firewall secondaire
- Maintien de la connectivité réseau

Test 2 : Sécurité VPN

Objectif :

Valider l'accès sécurisé depuis un réseau externe vers les ressources autorisées uniquement.

Procédure :

- Connexion via VPN depuis un poste distant
- Test d'accès à :
 - Serveur DMZ via le ping vers 10.10.10.10
 - Réseau interne qui est un accès interdit (192.168.X.X)

PC médecin distant

```
C:\>ping 8.8.8.8

Pinging 8.8.8.8 with 32 bytes of data:

Reply from 8.8.8.8: bytes=32 time<1ms TTL=127
Reply from 8.8.8.8: bytes=32 time<1ms TTL=127
Reply from 8.8.8.8: bytes=32 time<1ms TTL=127
Reply from 8.8.8.8: bytes=32 time<1ms TTL=127

Ping statistics for 8.8.8.8:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms

C:\>ping 10.10.10.10

Pinging 10.10.10.10 with 32 bytes of data:

Reply from 200.0.0.2: bytes=32 time=9ms TTL=124
Reply from 200.0.0.2: bytes=32 time=1ms TTL=124
Reply from 200.0.0.2: bytes=32 time<1ms TTL=124
Reply from 200.0.0.2: bytes=32 time=22ms TTL=124

Ping statistics for 10.10.10.10:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 22ms, Average = 8ms

C:\>ping 192.168.20.5

Pinging 192.168.20.5 with 32 bytes of data:

Reply from 200.0.0.2: Destination host unreachable.
Reply from 200.0.0.2: Destination host unreachable.
Reply from 200.0.0.2: Destination host unreachable.
Reply from 200.0.0.2: Destination host unreachable.

Ping statistics for 192.168.20.5:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\>
```

Firewall externe

```
Firewall_Ext#show crypto isakmp sa
IPv4 Crypto ISAKMP SA
dst          src          state          conn-id slot status
50.0.0.2     200.0.0.2    GM_IDLE        1040      0 ACTIVE

IPv6 Crypto ISAKMP SA
```

Résultats attendus :

- Accès autorisé vers la DMZ
- Accès refusé vers le LAN interne

Destination	Résultat (Ping)	État de l'accès	Implication Sécurité
Serveur DMZ (10.10.10.10)	Succès	Autorisé	Accès aux portails métiers OK

LAN interne (192.168.20.5)	Échec	Refusé	Étanchéité du cœur préservée
---------------------------------------	--------------	--------	------------------------------

Test 3 : Connectivité réseau globale

Objectif :

Vérifier le bon fonctionnement des communications internes et externes grâce aux ACLs.

Procédure :

- Test de connectivité depuis le LAN vers :
 - Internet
 - Serveur DMZ

ping 8.8.8.8 et ping 10.10.10.10

```

C:\>ping 192.168.20.5
|
Pinging 192.168.20.5 with 32 bytes of data:

Reply from 192.168.30.1: Destination host unreachable.
Reply from 192.168.30.1: Destination host unreachable.
Reply from 192.168.30.1: Destination host unreachable.
Reply from 192.168.30.1: Destination host unreachable.

Ping statistics for 192.168.20.5:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\>ping 192.168.10.5

Pinging 192.168.10.5 with 32 bytes of data:

Reply from 192.168.30.1: Destination host unreachable.
Reply from 192.168.30.1: Destination host unreachable.
Reply from 192.168.30.1: Destination host unreachable.
Reply from 192.168.30.1: Destination host unreachable.

Ping statistics for 192.168.10.5:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\>ping 8.8.8.8

Pinging 8.8.8.8 with 32 bytes of data:

Reply from 8.8.8.8: bytes=32 time=23ms TTL=123
Reply from 8.8.8.8: bytes=32 time=30ms TTL=123
Reply from 8.8.8.8: bytes=32 time=29ms TTL=123
Reply from 8.8.8.8: bytes=32 time=27ms TTL=123

Ping statistics for 8.8.8.8:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 23ms, Maximum = 30ms, Average = 27ms

C:\>

```

C'est un exemple de ping à partir du PC qui est connecté au point d'accès, comme vous pouvez le voir, les terminaux des autres VLANs sont inaccessibles, mais les visiteurs peuvent néanmoins se connecter au serveur DMZ et Internet.

Résultat attendu :

- Accès fonctionnel aux ressources autorisées

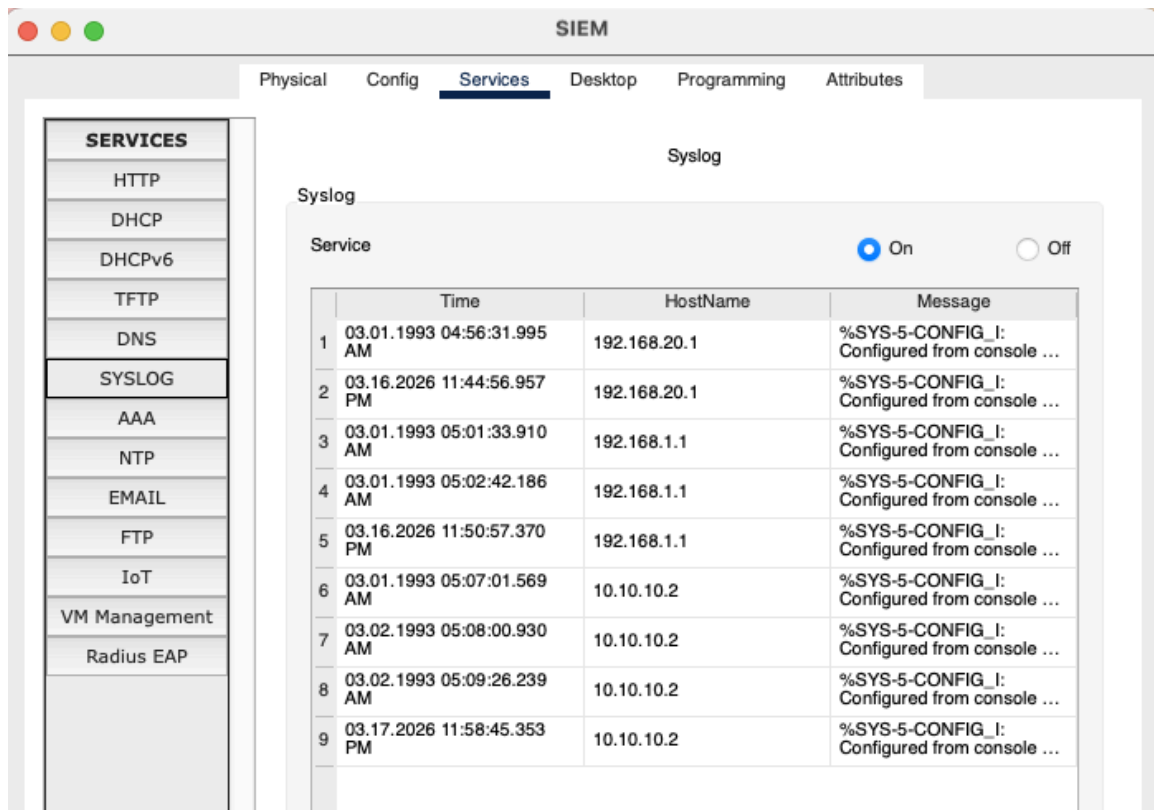
Test 4 : Supervision et journalisation (SIEM)

Objectif :

Vérifier la traçabilité des événements réseau et de sécurité.

Procédure :

- Génération d'événements :
 - Coupure d'interface avec la commande shutdown
 - Basculement d'interface au niveau des firewall routeurs internes
- Consultation des logs dans le SIEM



Résultat attendu :

- Visualisation des événements en temps réel

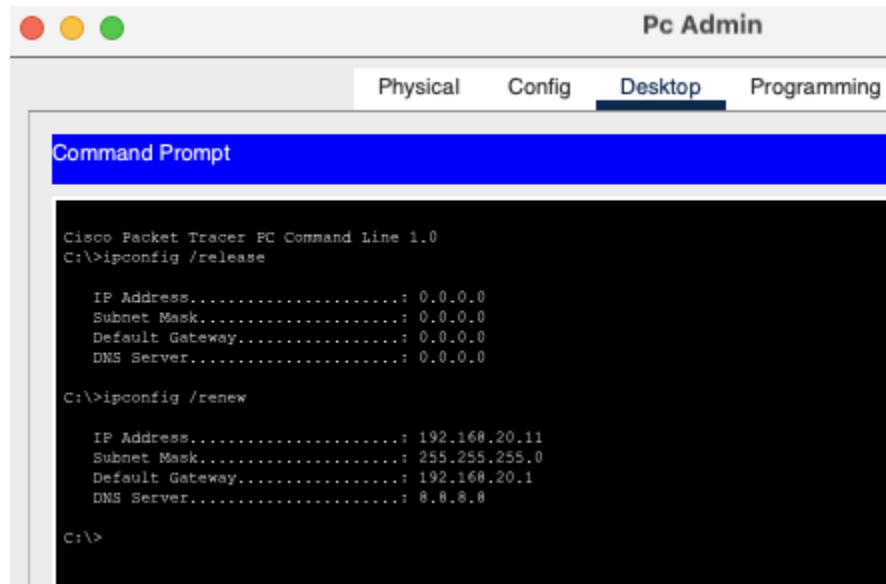
Test 5 : Sécurité DHCP (DHCP Snooping)

Objectif :

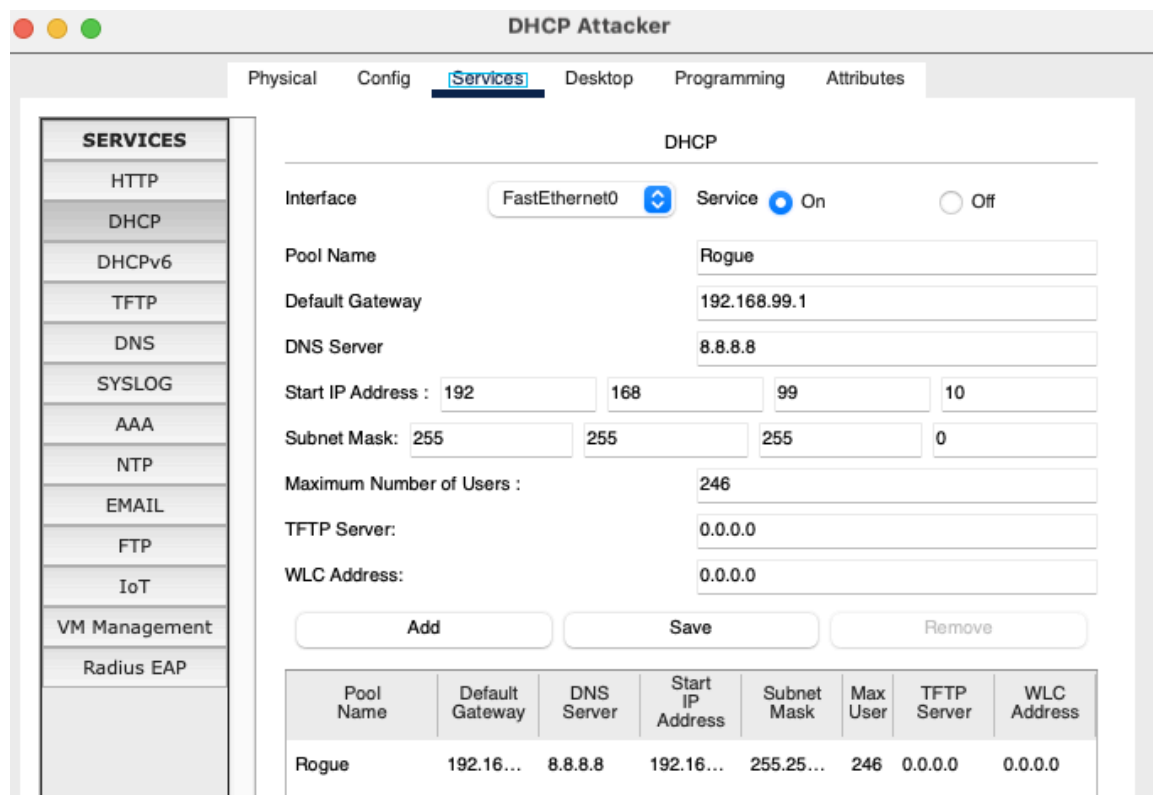
Empêcher l'introduction de serveurs DHCP non autorisés (attaque DHCP Rogue)

Procédure :

1. Vérification du fonctionnement normal du DHCP



2. Simulation d'un faux serveur DHCP



3. Analyse du comportement du switch

```
Multilayer-Switch0#show ip dhcp snooping binding
-----
MacAddress      IpAddress      Lease(sec)  Type           VLAN  Interface
-----
00:60:5C:DE:5E:48  192.168.10.11  0           dhcp-snooping  10    FastEthernet0/2
00:0C:CF:6E:7E:40  192.168.20.11  0           dhcp-snooping  20    FastEthernet0/3
Total number of bindings: 2
Multilayer-Switch0#
```

Comme on peut le voir, les adresses IP prises en compte sont celles qui appartiennent au réseau 192.168.10.X ou 192.168.20.X

Résultats attendus :

- Attribution d'adresses IP uniquement par le serveur légitime
- Blocage des serveurs DHCP non autorisés

Conclusion

Les tests réalisés démontrent que l'architecture proposée répond aux exigences d'Akdital en matière de :

- Sécurité des systèmes d'information
- Continuité de service
- Contrôle des accès
- Supervision des activités réseau

La solution mise en place est :

- Fiable
- Sécurisée
- Résiliente
- Adaptée aux contraintes du secteur médical